

PHISHSTRIKE

Software Requirements Specification (SRS)

Fighting Email Attacks

مكافحة هجمات البريد الإلكتروني

Project Type: Web-based Cybersecurity Tool

Languages: Arabic and English

Document Version: 1.0

Author: Eng. Hajar Almutairi

Primary source: PhishStrike Graduation Project report (2026)
plus the confirmed implementation requirements supplied by the project team.

1. Project Overview

PhishStrike is a bilingual web-based cybersecurity tool that allows a user to enter an email address, check it against trusted sources of known breach information, calculate a transparent security risk level, and receive practical security recommendations. The system is intended for technical and non-technical users and must protect privacy by minimizing collection and avoiding permanent storage of scan data.

A result that finds no known breach must be described carefully: it means that no known breach was found within the data sources checked by the system. It is not a guarantee that the email address has never been exposed.

2. Main Features

Feature	Description
Email Check	User enters an email and checks if it appears in known data breaches.
Risk Assessment	The system determines the risk level using predefined security rules.
Results	Shows breach status, risk level, relevant details, and security recommendations.
Security Warning	Displays a warning and optional audio alert when a risk is detected.
Arabic & English	Supports both languages, including RTL for Arabic.
Security & Privacy	Uses HTTPS, validates input, protects API keys, does not request passwords, and does not permanently store scan data.

3. Functional Requirements

ID	Requirement	Specification
FR-01	System Access	The system shall provide a web-based interface that users can access without entering email account credentials.
FR-02	Language Selection	The system shall allow the user to switch between Arabic and English.
FR-03	Email Input	The system shall allow the user to enter the email address to be checked.
FR-04	Validation	The system shall validate the email format before starting a breach check and show a clear error for invalid input.
FR-05	Breach Check	The system shall check emails against a trusted breach-data source.
FR-06	Risk Calculation	The system shall calculate a deterministic risk score and classification using the rule set in Section 5. No AI/LLM shall determine the risk level.
FR-07	Results	The system shall display whether known breaches were found, the risk level, and relevant breach information where available.
FR-08	Recommendations	The system shall display security recommendations appropriate to the result, including password changes, review of reused credentials, enabling two-factor authentication, and account monitoring when relevant.
FR-9	Security Warning	When a security risk is detected, the system shall display a clear visual warning and provide an optional audio alert.
FR-10	Email Alert	When a security risk is detected, the system shall support sending a security alert email containing a concise risk summary and recommended protective actions.
FR-11	Privacy & Errors	The system shall protect user data, avoid storing scan data permanently, and show clear error messages when a scan fails.

4. Risk Assessment

The risk engine shall be transparent, deterministic, and rule-based. The detailed GP risk framework takes priority over the simpler example ranges supplied in the confirmed requirements. It uses four scored factors (0-10 each) and a weighted formula:

Factor	Weight	Rule Basis
Recency (R)	0.30	Newer breaches receive higher scores; older breaches receive lower scores.
Sensitivity (S)	0.35	Passwords, financial data, and identity information are treated as more sensitive than email-only/public data.
Frequency (F)	0.20	Repeated appearance in multiple breaches increases the score.
Exposure Type (E)	0.15	Plain-text credentials score higher than hashed passwords, partial data, or email-only exposure.

Formula: Risk Score = $(0.30 \times R + 0.35 \times S + 0.20 \times F + 0.15 \times E) \times 10$. Factor scores are on a 0-10 scale, producing a final 0-100 score.

Level	Score	User-facing meaning / action
Safe	0-20	No significant known exposure detected in the checked sources. No immediate action, but normal security hygiene still applies.
Low	21-40	Minor/limited exposure. Review affected accounts and update weak or reused passwords.
Medium	41-60	Moderate exposure. Change relevant passwords, enable 2FA, and review connected accounts.
High	61-80	Significant exposure involving sensitive or repeated breach data. Immediate password reset, 2FA, and closer account monitoring are recommended.
Critical	81-100	Severe exposure involving highly sensitive data and/or multiple serious breaches. Immediate credential reset and comprehensive protective action are required.

Important: These thresholds are project-defined initial rules inspired by cybersecurity risk-assessment principles. They are not scientifically proven universal thresholds and should be validated with controlled test cases. The label "Safe" never means guaranteed safety.

5. Security & Privacy Requirements

ID	Area	Requirement
SEC-01	No Credentials	The system shall never request a user password, mailbox password, login token, or other email login credential.
SEC-02	HTTPS	All communication shall use HTTPS/TLS.
SEC-03	API Security	API keys and sensitive configuration shall be kept on the server and not exposed to users.
SEC-04	Data Privacy	The system shall collect only the data needed for the email check and shall not permanently store scan data.
SEC-05	Input Security	User input shall be validated to reduce common security risks.
SEC-06	Rate Limiting	The system shall limit excessive requests to reduce abuse.

6. Bilingual / Localization Requirements

PhishStrike shall support both Arabic and English. Users shall be able to switch between languages at any time. The Arabic interface shall use RTL (right-to-left) layout, while English shall use LTR (left-to-right) layout. All user-facing content, including results, warnings, recommendations, and error messages, shall be available in both languages with the same meaning and functionality.

7. Non-Functional Requirements

ID	Quality	Requirement
NFR-01	Performance	The system should return results within a reasonable time under normal conditions.
NFR-02	Usability	The interface shall be simple and understandable for both technical and non-technical users.
NFR-03	Compatibility	The website should work on modern browsers and different screen sizes.
NFR-04	Reliability	The system should provide consistent results and should not show a safe result if the breach service fails.

8. Proposed Technology

The GP report specifies a Python/Flask web implementation, so this SRS treats that stack as the report-aligned baseline. The confirmed React/Next.js and FastAPI stack remains an acceptable modernization option if the team chooses it, but it is not required by the SRS.

Component	Proposed Baseline	Notes
Frontend	HTML/CSS/JavaScript (GP baseline)	React/Next.js may be used instead if preferred; bilingual/RTL behavior remains mandatory.
Backend	Python + Flask (GP baseline)	FastAPI is an acceptable alternative if the same API/security behavior is preserved.
Breach Checking	Have I Been Pwned (HIBP) API	Primary proposed external source for known breach information; implementation must follow current provider API rules and rate limits.
Persistent Storage	None for scan email/results	Email addresses and scan results are processed temporarily and not stored.
Security	HTTPS/TLS + server-side secret management	Do not place external API keys in frontend code.
Development	GitHub + Figma	Source control/collaboration and UI/UX prototyping as identified in the GP report.

9. Expected Outcomes

The expected result is a functional bilingual web application that can accept and validate an email address, check it against known breach information, calculate a transparent rule-based risk level, display the result clearly, provide relevant recommendations and warnings, and follow basic security and privacy practices.

- Users can understand whether known breach records were found without needing cybersecurity expertise.
- Risk is communicated using the defined score and classification, with specific protective actions.
- Arabic and English users receive equivalent results, warnings, and security guidance.
- The application avoids passwords/login credentials and does not permanently retain scan data.
- The design remains simple enough for a beginner development team to implement and test.